

Manual 31 — Implementação controlada do NYDFS 23 NYCRR Part 500

****Idioma:**** Português do Brasil (pt-BR)

****Linha de base regulatória:**** 23 NYCRR Part 500, alterado pela Segunda Emenda com vigência em 1º de novembro de 2023 e reverificado para publicação em 31 de agosto de 2026.

****Limite controlado:**** Esta edição é uma tradução não oficial e orientação de implementação. Não presta assessoria jurídica, não determina condição de Covered Entity ou Class A Company, não estabelece isenção, não realiza filing regulatório e não certifica conformidade. Regulamento vinculante, materiais explicativos do DFS, prática organizacional e evidência permanecem separados.

Chapter 01 — Propósito, escopo e hierarquia controlada de fontes

Use Part 500 e os materiais finais de adoção do DFS como camada vinculante. Trate FAQs, treinamentos, checklists, cronogramas, explicações do Resource Center e industry letters como material explicativo ou consultivo datado; procedimentos internos nunca devem ser apresentados como o regulamento.

Chapter 02 — Aplicabilidade e análise de Covered Entity

Mantenha avaliação documentada de aplicabilidade identificando a autorização do DFS e as atividades reguladas relevantes. Encaminhe dúvidas sobre entidade, afiliada, filial ou perímetro regulatório para análise jurídica/regulatória qualificada em vez de inferir status por descrição genérica.

Chapter 03 — Definições e governança terminológica

Mantenha glossário controlado para Covered Entity, Cybersecurity Event, Information System, Nonpublic Information, Senior Governing Body, CISO, Class A Company e Third Party Service Provider. Preserve o significado regulatório quando a terminologia interna for diferente.

Chapter 04 — Isenções e controles de isenção limitada

Documento base regulatória, fatos, aprovação, status do filing, vigência, obrigações remanescentes e gatilhos de mudança para cada isenção. Revalide quando tamanho, receita, operações, afiliação ou outros fatos relevantes mudarem.

Chapter 05 — Determinação de Class A Company e obrigações

Mantenha determinação datada de Class A Company baseada na definição regulatória vigente e nos fatos aplicáveis. Quando cabível, identifique requisitos reforçados sem estendê-los a entidades para as quais Part 500 não os exige.

Chapter 06 — Governança de cibersegurança e accountability superior

Defina responsabilidades do Senior Governing Body, reporting gerencial, escalonamento, decisões de recursos e aceitação de risco. A evidência deve demonstrar supervisão informada, não apenas presença do tema cibersegurança em uma pauta.

Chapter 07 — Papel, autoridade, reporting e evidência do CISO

Documente autoridade, independência ou linha de reporte, responsabilidades, recursos e relatórios exigidos do CISO. Preserve relatórios, achados, questões materiais, decisões de remediação e evidência de revisão.

Chapter 08 — Desenho e manutenção do programa de cibersegurança

Opere programa baseado em risco para proteger Information Systems e Nonpublic Information e apoiar detecção, resposta, recuperação e deveres regulatórios. Mapeie componentes a proprietários, políticas, procedimentos, tecnologia, evidência e testes.

Chapter 09 — Estrutura de políticas de cibersegurança

Mantenha políticas escritas aprovadas cobrindo os tópicos de Part 500 aplicáveis. Cada política deve indicar proprietário, escopo, autoridade de aprovação, revisão, procedimentos, evidências, exceções e gatilhos de mudança.

Chapter 10 — Metodologia de risk assessment

Execute e mantenha a risk assessment exigida por Part 500 com critérios definidos, ameaças, vulnerabilidades, operações, sistemas, Nonpublic Information, controles e mudanças materiais. Preserve metodologia, entradas, premissas, aprovações, riscos e decisões de tratamento.

Chapter 11 — Inventário de ativos e ciclo de vida tecnológico

Mantenha o inventário de Information Systems exigido pelo regulamento alterado, com atributos, propriedade, atualização e retenção adequados. Reconcilie a cobertura de nuvem, endpoints, servidores, aplicações, redes, dados, IA e outras tecnologias relevantes.

Chapter 12 — Privilégios de acesso e menor privilégio

Limite acesso de acordo com responsabilidades e necessidade legítima. Defina provisionamento, aprovação, revisão periódica, transferência, desligamento, acesso emergencial, exceções e evidência de adequação contínua.

Chapter 13 — Gestão de acesso privilegiado

Aplique governança reforçada a contas privilegiadas, contas de serviço e ferramentas administrativas. Registre proprietário, necessidade, autenticação, monitoramento, revisão, salvaguardas, uso emergencial e remoção tempestiva.

Chapter 14 — Requisitos de MFA e exceções

Implemente MFA de acordo com Part 500 alterado e os fatos aplicáveis. Toda alternativa ou exceção permitida deve registrar base regulatória, aprovação do CISO quando exigida, risco, controles compensatórios, escopo, duração e gatilho de revalidação.

Chapter 15 — Gestão de vulnerabilidades e penetration testing

Opere scanning/avaliação de vulnerabilidades, remediação, penetration testing e acompanhamento baseado em risco na frequência e no escopo aplicáveis. Preserve metodologia, achados, severidade, remediação, reteste e exceções.

Chapter 16 — Desenvolvimento seguro e segurança de aplicações

Mantenha procedimentos escritos de desenvolvimento seguro e application security para aplicações internas e externas quando aplicável. Inclua desenho seguro, revisão de código/mudança, dependências, testes, remediação e aprovação de release.

Chapter 17 — Criptografia e decisões sobre controles compensatórios

Proteja Nonpublic Information em trânsito e em repouso com criptografia compatível com Part 500. Quando alternativa permitida for necessária, documente decisão, aprovação, controles compensatórios, risco, duração, monitoramento e reconsideração periódica.

Chapter 18 — Monitoramento, logging e detecção

Implemente monitoramento baseado em risco da atividade de usuários autorizados e controles destinados a detectar acesso, uso ou adulteração não autorizados. Mantenha logging, alertas, revisão, retenção, tuning, escalonamento e investigação.

Chapter 19 — Salvaguardas de endpoint, rede e infraestrutura

Aplique salvaguardas baseadas em risco contra código malicioso e atividade não autorizada em endpoints, redes, e-mail, web, acesso remoto, infraestrutura e canais administrativos. Separe requisitos específicos de Class A das obrigações-base.

Chapter 20 — Risco de cibersegurança de Third Party Service Providers

Mantenha programa/política para Third Party Service Providers cobrindo avaliação, due diligence, práticas mínimas, contratos, acesso, notificação de incidentes, monitoramento e encerramento. Terceirização não elimina as responsabilidades da Covered Entity sob Part 500.

Chapter 21 — Conscientização e treinamento

Forneça treinamento periódico, no mínimo anual, e atualize-o com base nos riscos identificados. Inclua engenharia social e preserve população, conclusão, exceções, versão do conteúdo, data e acompanhamento.

Chapter 22 — Planejamento e execução de incident response

Mantenha plano cobrindo preparação, papéis, escalonamento, investigação, contenção, erradicação, recuperação, comunicações, evidência, análise regulatória, lições aprendidas e atualização. Exercícios e eventos reais devem gerar remediação rastreável.

Chapter 23 — Business continuity e disaster recovery

Mantenha planos BCDR alinhados ao Part 500 alterado e a cenários cibernéticos. Defina operações críticas, objetivos de recuperação, backups, testes de restauração, dependências, comunicações, testes e melhorias.

Chapter 24 — Determinação e escalonamento de Cybersecurity Event

Use processo documentado para decidir se uma ocorrência atende à definição regulatória de Cybersecurity Event e se aciona limiares adicionais. Preserve fatos, momento de conhecimento, análise, responsável pela decisão e escalonamento.

Chapter 25 — Aviso ao Superintendent e registros de decisão

Mantenha processo sensível ao tempo para eventos reportáveis ao DFS. Registre critérios, timestamps, autoridade, informações apresentadas, comunicações suplementares, confirmação do portal e evidência; não substitua o teste regulatório por severidade interna.

Chapter 26 — Notificação de extortion payment e limites de evidência

Mantenha processo controlado para pagamentos de extorsão que possam acionar notificação ou informações de acompanhamento. Preserve autorização, tempos, fatos do pagamento, revisão jurídica/sanções quando aplicável, análise e evidência de notificação.

Chapter 27 — Governança de certificação / acknowledgment anual

Opere processo anual que diferencie certificação de material compliance de acknowledgment of noncompliance quando aplicável. Mantenha signatários responsáveis, evidência, lacunas conhecidas, remediação, fundamento da decisão e confirmação do filing.

Chapter 28 — Supervisão do Senior Governing Body e retenção

Forneça informação suficiente sobre riscos materiais, incidentes, lacunas, reporting do CISO, remediação, exceções, recursos e mudanças significativas. Preserve atas, materiais, aprovações e acompanhamento sem apresentá-los como asseguração independente.

Chapter 29 — Governança de remediação, exceções e aceitação de risco

Gerencie deficiências com proprietário, severidade, causa raiz, ações, data-alvo, salvaguardas interinas, validação e encerramento. Aceitação de risco não pode eliminar silenciosamente uma obrigação de Part 500.

Chapter 30 — Testes, métricas, asseguração e melhoria contínua

Defina testes e métricas que demonstrem operação e degradação do programa. Preserve escopo, população, método, resultados, limitações, tendências, acompanhamento e independência quando exigida; percentuais de dashboard não comprovam conformidade.

Chapter 31 — Arquitetura de evidência, auditabilidade e retenção

Mantenha evidência rastreável entre tema regulatório, política, procedimento, proprietário, sistema, período, teste, exceção, achado, remediação, aprovação e versão da fonte. Proteja informações sensíveis e aplique retenção conforme obrigações aplicáveis.

Chapter 32 — Controle de mudança regulatória e roadmap de implementação

Revalide Part 500 e o DFS Cybersecurity Resource Center antes de cada release. Avalie emendas, FAQs, guidance, enforcement, advisories, mudanças de filing e deadlines e atualize mapeamentos, procedimentos, evidências, treinamento e planos por mudança controlada.

Conjunto mínimo de evidências

Mantenha, conforme aplicável: registro de fonte/versão; análise de aplicabilidade; determinações de isenção e Class A; mandato e relatório do CISO; programa; políticas; risk assessment; inventário; revisões de acesso; decisões de MFA; evidência de vulnerabilidades/penetration testing; application security; criptografia; monitoramento; terceiros; treinamento; incidentes/BCDR; análises e confirmações de reporting ao DFS; certificação/acknowledgment anual; supervisão do Senior Governing Body; remediação/exceções; métricas/testes; e verificação de fontes de release.